evaluation version of ForgeRock Access Management 6.5.2, which supports the standard.

Certificate-bound tokens and public clients

An interesting aspect of the OAuth2 mTLS specification is that a client can request certificate-bound access tokens even if they don't use mTLS for client authentication. In fact, even a public client with no credentials at all can request certificate-bound tokens! This can be very useful to upgrade the security of public clients. For example, a mobile app is a public client because anybody who downloads the app could decompile it and extract any credentials embedded in it. However, many mobile phones now come with secure storage in the hardware of the phone. An app can generate a private key and self-signed certificate in this secure storage when it first starts up and then present this certificate to the AS when it obtains an access token to bind that token to its private key. The APIs that the mobile app then accesses with the token can verify the certificate binding based purely on the hash associated with the token, without the client needing to obtain a CA-signed certificate.

POP QUIZ

Answers are at the end of the chapter.

8. Which of the following checks *must* an API perform to enforce a certificate-bound access token? Pick all essential checks.

a) Check the certificate has not expired.

b) Ensure the certificate has not expired.

c) Check basic constraints in the certificate.

d) Check the certificate has not been revoked.

e) Verify that the certificate was issued by a trusted CA.